PRAVEEN V 241901082

# Exercise 5
# Web Server Reconnaissance

## AIM

To perform reconnaissance on a target web server in order to identify the server type, version, operating system, open ports, running services and possible vulnerabilities using footprinting and scanning tools.

## PROCEDURE

### Part A: Banner Grabbing

1. Open a terminal in Kali Linux.
2. Use Netcat to connect to the target web server and grab the banner:
   nc testphp.vulnweb.com 80
   Then type: HEAD / HTTP/1.1 and press Enter twice.
3. Note the server details returned in the response header (Server, X-Powered-By).
4. Alternatively, use telnet:
   telnet testphp.vulnweb.com 80

### Part B: Server Fingerprinting Tools

1. Run WhatWeb to identify the web server and technologies:
   whatweb testphp.vulnweb.com
2. Run Nikto to scan the web server for vulnerabilities, outdated software and misconfigurations:
   nikto -h testphp.vulnweb.com

3. Run httprecon or wafw00f to detect the server type and check for a Web Application Firewall:
   wafw00f testphp.vulnweb.com

**Part C: Port and Service Scanning**

1. Run an Nmap scan to identify open ports and services on the web server:
   nmap -sV testphp.vulnweb.com
2. Run an aggressive scan to detect OS and service versions:
   nmap -A testphp.vulnweb.com
3. Note the open ports (80, 443, etc.), running services and detected OS.

**Part D: Directory and File Enumeration**

1. Use Dirb or Gobuster to find hidden directories and files on the web server:
   dirb http://testphp.vulnweb.com
   or
   gobuster dir -u http://testphp.vulnweb.com -w /usr/share/wordlists/dirb/common.txt
2. Note any sensitive directories, admin panels or backup files discovered.

**OBSERVATION TABLE**

| S.No | Tool / Technique | Information Gathered | Observation |
|---|---|---|---|
| 1 | Netcat / Telnet banner grab | HTTP response headers | Server type and version identified |
| 2 | WhatWeb | Web technologies used | CMS, language, |

| S.No | Tool / Technique | Information Gathered | Observation |
|---|---|---|---|
| | | | frameworks identified |
| 3 | Nikto | Vulnerabilities and misconfigurations | Outdated software and risky files found |
| 4 | wafw00f | WAF detection | Presence/absence of a firewall identified |
| 5 | Nmap (-sV) | Open ports and service versions | List of running services obtained |
| 6 | Nmap (-A) | OS detection and detailed service info | Operating system identified |
| 7 | Dirb / Gobuster | Hidden directories and files | Admin panels/backup files discovered |

**OUTPUT**

Banner grab output:
HTTP/1.1 200 OK
Server: nginx/1.19.0
X-Powered-By: PHP/5.6.40

WhatWeb output:
http://testphp.vulnweb.com [200 OK] HTTPServer[nginx/1.19.0], PHP[5.6.40], IP[44.228.249.3]

Nikto output:

- Server: nginx/1.19.0
- The X-XSS-Protection header is not defined
- /admin/: Admin login page found

- OSVDB-3092: /login.php: Login page found

Nmap -sV output:
PORT STATE SERVICE VERSION
80/tcp open http nginx 1.19.0
443/tcp closed https

Gobuster output:
/admin (Status: 200)
/login.php (Status: 200)
/uploads (Status: 200)
/backup.zip (Status: 200)

**RESULT**

Thus, web server reconnaissance was successfully performed on the target server. The server type, version, operating system, open ports, running services, hidden directories and potential vulnerabilities were identified using banner grabbing, fingerprinting and scanning tools.